

TrustEpisode: Calibrated Episode Risk Scoring with Evidence-Grounded Agentic RAG for Multi-Step Cyber Attacks

Anonymous Author(s)

ABSTRACT

Multi-step cyber attacks, including advanced persistent threats (APTs) and ransomware campaigns, rarely manifest as a single decisive alert. Instead, they unfold through temporally dispersed, heterogeneous, and partially inconsistent observations across endpoint activity, network telemetry, identity events, asset context, operational technology visibility, and cyber-threat intelligence. Existing security operations commonly rely on static correlation rules that are difficult to adapt across environments, while LLM-based security agents can produce plausible but insufficiently calibrated risk assessments when evidence is incomplete, stale, or contradictory.

We present TRUSTEPISODE, a multi-layer framework for calibrated and evidence-traceable episode risk scoring over heterogeneous security telemetry. The Evidence Fabric Layer transforms observations into a temporally aligned evidence graph with provenance, reliability, freshness, and asset-context annotations. The Episode Synthesis Layer groups related observations into candidate attack episodes. The Calibrated Trust Scoring Layer separates maliciousness likelihood, operational impact, operational priority, and evidence sufficiency: asset criticality affects consequence rather than maliciousness, while missing telemetry produces uncertainty caveats rather than benign labels. Unlike fully rule-based correlation, TRUSTEPISODE learns score calibration from observed benign and attack behavior while retaining factor-level interpretability. An Agentic Evidence Assurance Layer applies evidence-grounded retrieval to retrieve supporting and contradicting evidence, identify missing observations, and produce cited narratives; it does not directly assign or overwrite the numerical score.

We evaluate TRUSTEPISODE through a three-tier empirical protocol: public DARPA Transparent Computing traces, controlled Caldera-based breach-and-attack simulations, and anonymized enterprise telemetry for external validation. We measure episode reconstruction, risk ranking, calibration, robustness to telemetry loss and misleading CTI, evidence traceability, and time to analyst-verifiable conclusions.

KEYWORDS

multi-step attack detection, calibrated risk scoring, provenance, security telemetry, agentic RAG, cyber threat intelligence

1 INTRODUCTION

Security operations centers receive heterogeneous alerts from endpoint detection and response (EDR), network detection and response (NDR), identity systems, system logs, asset inventories, operational technology (OT) monitoring, and cyber-threat intelligence (CTI) feeds. APT and ransomware campaigns are not normally represented by one conclusive alarm. They appear as an evolving sequence of weak signals: an unusual remote connection,

a suspicious script, a credential-access indicator, lateral movement, and finally an impact precursor. Each element alone can be benign, incomplete, or too low-confidence to merit escalation.

The central operational question is therefore not only whether an event is anomalous. It is whether a set of heterogeneous observations should be assembled into one candidate attack episode, how much confidence should be assigned to that episode, and whether the resulting score is sufficiently grounded for analyst action. Static SIEM and XDR correlation commonly rely on manually tuned rule chains and severity aggregation. These mechanisms are fast and interpretable, but are brittle when behavior differs across sites, telemetry is partially missing, or normal administration resembles attacker tradecraft. At the opposite extreme, deep graph methods and LLM-based triage can improve recall or narrative quality but often weaken score calibration, repeatability, and factor-level explanation.

CAPTAIN demonstrates that a rule-oriented provenance detector can be made adaptive by learning fine-grained node, edge, and threshold parameters through differentiable tag propagation [15]. Its central insight is important: systems should retain lightweight, semantically meaningful detection mechanisms while learning deployment-specific configurations. TRUSTEPISODE extends this insight beyond host provenance into heterogeneous, episode-level operational risk scoring. We treat an attack episode as a temporal evidence subgraph spanning endpoint, network, identity, context, and CTI observations, and explicitly separate (i) episode formation, (ii) calibrated risk scoring, and (iii) evidence assurance.

This separation is especially important for Agentic RAG. CTI, historical cases, and policy documents can be valuable for investigation, but retrieved text may be stale, contradictory, irrelevant to local context, or adversarially influenced. Therefore, TRUSTEPISODE uses Agentic RAG to retrieve support, contradiction, and missing evidence, while the numerical score remains under a constrained learnable scoring model. The agent can explain and challenge a score; it cannot silently replace it.

Research question. How can a security system assign calibrated, interpretable, and evidence-traceable risk scores to multi-step attack episodes formed from heterogeneous telemetry without relying solely on fixed rules or unconstrained LLM judgment?

Contributions. This paper makes four contributions:

- (1) We introduce TRUSTEPISODE, a multi-layer framework that converts heterogeneous security telemetry into prioritized, evidence-traceable attack episodes.
- (2) We propose a constrained learnable episode scorer that separates calibrated maliciousness likelihood, operational impact, operational priority, and evidence sufficiency while retaining factor-level interpretability.

- (3) We define an Agentic Evidence Assurance Layer that retrieves supporting, contradicting, and missing evidence without directly controlling numerical risk scores.
- (4) We specify a three-tier evaluation protocol using public provenance-rich traces, controlled Caldera BAS scenarios, and anonymized enterprise validation.

2 RELATED WORK

2.1 Provenance and Graph-Based Intrusion Detection

Provenance-based intrusion detection systems (PIDS) construct causal graphs in which nodes represent system entities and edges capture information-flow or execution relations. This structure is effective for reconstructing attack paths and preserving causal context. Existing methods range from graph embeddings and neural detectors to rule-based propagation and graph matching. CAPTAIN positions itself in the latter family, adapting rule-based PIDS by optimizing node initialization, edge propagation, and alarm thresholds while retaining low overhead and interpretability [15]. However, many provenance detectors remain host-centric and issue alarms at the node, edge, or subgraph level. They do not directly produce calibrated, cross-source, episode-level operational risk scores.

2.2 Adaptive Correlation and Risk-Based Security Operations

Alert aggregation, SIEM correlation, attack-path prioritization, and XDR risk scoring aim to reduce analyst load. Yet alert counts and vendor severity labels are not synonymous with operational risk. A high-confidence indicator match can be irrelevant to the affected asset; conversely, several low-severity events can become significant when they form a coherent sequence. TRUSTEPISODE therefore models risk at the episode level and separates maliciousness likelihood from operational impact. The model learns locally appropriate contributions while preserving explicit semantic factors and policy constraints.

2.3 CTI, Retrieval-Augmented Analysis, and Security Agents

CTI can enrich detection through indicators, technique mappings, and adversary context, but intelligence is heterogeneous in freshness and reliability. Retrieval-augmented generation (RAG) improves the grounding of language-model outputs by augmenting generation with retrieved evidence [8]. In a security setting, however, direct LLM scoring can lead to uncalibrated risk judgments and overly confident explanations. TRUSTEPISODE treats CTI as a bounded, corroborative input and uses Agentic RAG only for assurance: evidence retrieval, contradiction discovery, gap identification, and citation-aware reporting. The agent is read-only with respect to the primary score and enforcement actions.

2.4 Calibration, Robustness, and Explanation

Risk ranking and risk calibration solve different problems. A model can rank malicious episodes near the top while systematically overestimating or underestimating their probability. This distinction matters when a score determines escalation thresholds, analyst attention, and the amount of evidence demanded before a potentially disruptive response. TRUSTEPISODE therefore uses calibration loss and reliability analysis as first-class evaluation targets rather than treating an anomaly value as a probability by default.

Robustness is similarly distinct from raw classification performance. In real operations, a network sensor may be absent, identity events may arrive late, asset inventory may be stale, and CTI may contain weak or contradictory indicators. We design the model so that absence of evidence changes the evidence-sufficiency state rather than being treated as proof of benignness or as a direct maliciousness penalty. The final score can therefore be accompanied by a caveat such as “high priority, but reduced confidence because NDR corroboration is unavailable.” This is a more actionable output than a single opaque anomaly score.

3 TRUSTEPISODE METHOD

TRUSTEPISODE transforms endpoint detection and response (EDR) and network detection and response (NDR) telemetry into deterministic candidate-episode revisions and version-scoped evidence records. The online path is label blind: the Evidence Fabric normalizes events and collector-health observations; Episode Synthesis alone owns event membership and immutable revisions; a stateless scorer maps two explicit evidence features to a raw logit; and an affine calibrator is the sole producer of a maliciousness probability when the current revision matches a supported manifest. A separate deterministic evaluator reports a structured evidence-sufficiency profile without changing that probability. Each revision produces exactly one append-only AuditRecord containing the raw score, nullable calibrated probability, sufficiency state, versions, provenance references, and canonical digest. Ground truth is joined only after inference for fitting or evaluation. The method therefore estimates whether a frozen candidate revision contains malicious activity under the observed EDR/NDR collection boundary; it does not estimate enterprise-wide risk, operational impact, response priority, or attacks that leave no observable trace. Figure 1 summarizes these ownership and trust boundaries.

3.1 Problem Scope, Output Contract, and Ownership

Let C be every EpisodeRevision emitted by the frozen formation policy. Let

$$C_{\text{sup}} = \{\epsilon^{(r)} \in C : \kappa_{\epsilon^{(r)}} \in \{\kappa_G, \kappa_g\}\} \quad (1)$$

where κ_G and κ_g denote supported_global and supported_group. This is the subset for which a calibration manifest supports a probability. The supervised target $Y_{\epsilon^{(r)}} \in \{0, 1\}$ states whether the immutable membership of revision $\epsilon^{(r)}$ contains malicious activity under a frozen temporal and entity-overlap policy. The label is joined offline only after that revision has completed online inference. A malicious action first observed in revision $r + 1$

Table 1: Positioning of TRUSTEPISODE relative to representative approach families.

Capability	Static correlation	PIDS / graph detection	LLM/RAG triage	CAPTAIN	TRUSTEPISODE
Heterogeneous telemetry fusion	Partial	Usually host-centric	Possible	Host provenance	Yes
Episode-level risk score	Limited	Partial	Informal	Edge / alarm-focused	Yes
Explicit probability calibration	Rare	Partial	No guarantee	Adaptive thresholds	Yes
Bounded CTI contribution	Rare	Rare	Often unclear	N/A	Yes
Factor-level score audit	Limited	Limited	Limited	Strong	Strong
Agentic evidence assurance	No	No	Yes	No	Yes
Agent directly assigns score	No	No	Often	No	No

cannot retroactively relabel revision r . Positive and negative revisions form the primary supervised cohort; mixed and ambiguous revisions are reported separately and enter only pre-registered sensitivity analyses.

For every $\epsilon^{(r)} \in C$, runtime emits a raw logit $z_{\epsilon^{(r)}}$, a calibration status $\kappa_{\epsilon^{(r)}}$, a nullable calibrated probability $P_{\epsilon^{(r)}}$, a structured sufficiency profile $U_{\epsilon^{(r)}}$, and exactly one immutable AuditRecord. When defined, P is candidate-conditioned and version-scoped:

$$P_{\epsilon^{(r)}} = \Pr(Y_{\epsilon^{(r)}} = 1 \mid \epsilon^{(r)}, v_{\text{episode}}, v_{\text{feature}}, v_{\text{model}}, v_{\text{cal}}). \quad (2)$$

It is not an unconditional probability that the organization is under attack.

The contract relies on three assumptions. The *observable-trace assumption* limits inference to traces visible inside the declared EDR/NDR scope. The *collector-boundary assumption* treats collector identity and transport metadata as authenticated while representing outages, delay, and parser failure explicitly. The *label-blind online assumption* forbids labels, scenario identifiers, split assignments, and ground-truth windows from every online object. Consequently, TRUSTEPISODE cannot guarantee detection of activity that leaves no relevant observable trace.

3.2 Evidence Fabric and Independent Source Health

The Evidence Fabric maps each source record to a NormalizedEvent containing a stable ID, event time, ingest time, source family and instance, canonical entities and action, an immutable raw pointer, and a root dependency group. Event time describes when the source observed an action; ingest time describes when the pipeline received it. The distinction is required for deterministic late-data handling [1]. Forwarded or derived copies inherit the same root dependency group and cannot create additional evidence. Normalization artifacts, including source-specific parsers and empirical transforms, are fitted or selected using training data and are read-only at runtime. OCSF v1.8.0 provides a field-name alignment target, not a claim of cross-vendor semantic equivalence [12].

SourceCoverage is a separate health stream produced by authenticated heartbeat, lag, parser, and transport observations. Absence of an event never implies that a collector is down. For source family $s \in \mathcal{S}^* = \{\text{EDR}, \text{NDR}\}$, define

$$m_{\epsilon, s} = \#[\epsilon \text{ contains an observed event from } s]. \quad (3)$$

The vector m_{ϵ} is the observed source mask; replay event masking can change m without changing health. The snapshot h_{ϵ} is resolved from SourceCoverage intervals that overlap the episode interval.

Finally, $q_{\epsilon, s} = 1$ only when s contains lineage-deduplicated supporting detection evidence tied to an episode core entity or edge. Thus a healthy but silent family can have $m = 0$ and health healthy; an observed family without supporting detection can have $m = 1, q = 0$. Neither m nor q alone diagnoses collector failure. The Scope Resolver jointly uses $(m_{\epsilon}, h_{\epsilon})$ and frozen pipeline versions to determine κ_{ϵ} . Appendix A.1 gives the contract-complete schema registry, canonical serialization, and firewall rules.

3.3 Deterministic Episode Synthesis and Immutable Revisions

Episode Synthesis is the only component that may attach, merge, or revise membership. For a new event e_i and an open episode E , eligibility is

$$\ell(e_i, E) = \#[\Delta_t(e_i, E) \leq W_{\text{gap}} \wedge R(e_i, E) = 1 \wedge \text{span}(E \cup \{e_i\}) \leq W_{\text{max}} \wedge H(e_i, E) = 0], \quad (4)$$

where Δ_t is the event-time inactivity gap, R denotes at least one frozen process-causal, authenticated-session, endpoint-mapped connection, or specific-entity relation, and H marks a forbidden hub-only link. Temporal proximity alone is insufficient.

Zero eligible candidates start a new episode; one candidate receives the event; multiple candidates are processed by the frozen total order and merge guard in Appendix A.2. The appendix also fixes canonical episode IDs, merge lineage, inclusive boundaries, and event ordering. Event time determines relation eligibility, whereas ingest time advances the watermark. Accepted evidence inside the revision horizon emits revision $r + 1$ and a new AuditRecord; evidence beyond the horizon follows the frozen late-store or drop policy. No path overwrites an earlier revision or its record. These controls apply the causal-context lessons of alert-correlation and provenance systems while retaining an auditable, deliberately compact candidate generator [3, 9–11].

Algorithm 1: label-blind episode update.

- (1) Normalize and dependency-deduplicate the incoming event.
- (2) Retrieve open candidates satisfying the inclusive temporal bounds.
- (3) Evaluate allowed non-temporal relations and forbidden hub links.
- (4) Apply giant-component and merge guards from the frozen policy.
- (5) Follow the frozen zero/one/multiple-candidate branch and total order.

Table 2: Single-owner online object contract.

Object	Sole producer	Consumers	Forbidden behavior
NormalizedEvent	Evidence Fabric	Episode Synthesis	label, split, or scenario fields
SourceCoverage	Health Monitor	Scope Resolver; Sufficiency Evaluator	infer outage from event silence
EpisodeRevision	Episode Synthesis	Feature Extractor; audit path	scorer-side membership change
FeatureVector $[D, C]$	Feature Extractor	Stateless Scorer	health, U , or label fields
Raw logit z	Stateless Scorer	Calibrator; AuditRecord	probability wording
CalibrationStatus κ	Scope Resolver	Calibrator; Sufficiency Evaluator; audit path	test-selected status
Nullable calibrated P	Calibrator	AuditRecord; downstream review	modification by U ; numeric value when unsupported
Structured U	Sufficiency Evaluator	AuditRecord; downstream review	replacement or recomputation of P
AuditRecord	Append-only audit store	Replay; evaluation; review	update of an earlier revision record

TrustEpisode online and offline boundaries

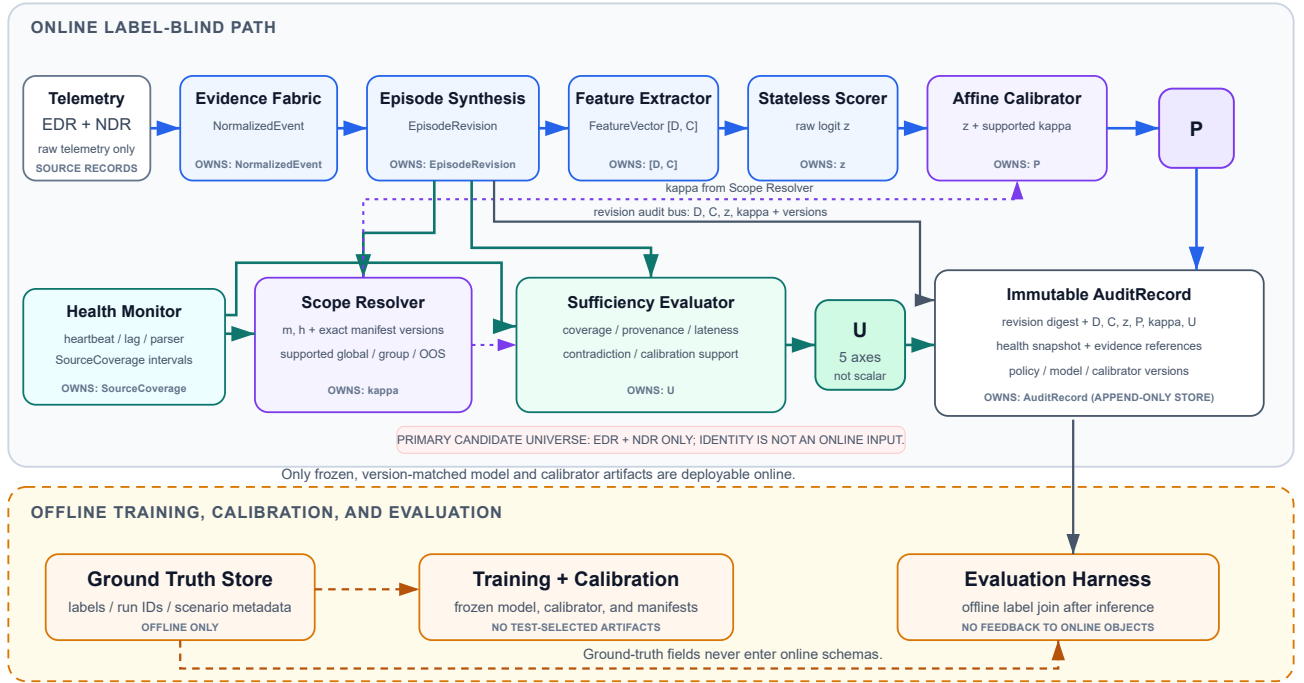


Figure 1: TRUSTEPISODE online and offline boundaries. The solid primary candidate path contains EDR/NDR only. Evidence Fabric, Episode Synthesis, Feature Extractor, Stateless Scorer, Scope Resolver, Calibrator, and Sufficiency Evaluator respectively own NormalizedEvent, EpisodeRevision, $[D, C]$, z , κ , P , and U . Identity is not an online input, and U has no numerical path into the scorer or calibrator.

- (6) Advance the ingest-time watermark and apply the revision-horizon rule.
- (7) Emit an immutable EpisodeRevision and exactly one new AuditRecord.

3.4 Compact Feature Semantics and Stateless Raw Scorer

The primary feature contract is

$$x_\epsilon = [D_\epsilon, C_\epsilon]. \quad (5)$$

For each eligible source-native detector value r_i , the frozen transform $d_i = \hat{F}_{s_i}^{\text{train, benign}}(r_i)$ maps the value through the empirical CDF fitted on training-benign observations from its source family. D_ϵ is the mean of the three largest eligible d_i values, or all values when fewer than three exist. If none exist, $D_\epsilon = 0$ is only a deterministic raw-model placeholder and $u_{\text{provenance}} = \text{missing}$. This is not benign evidence; unless the calibration manifest explicitly supports that regime, $P_\epsilon = \text{NA}$.

The primary scope is permanently fixed to

$$S^* = \{\text{EDR, NDR}\}, \quad K = 2, \quad (6)$$

Deterministic episode synthesis and immutable revision lifecycle

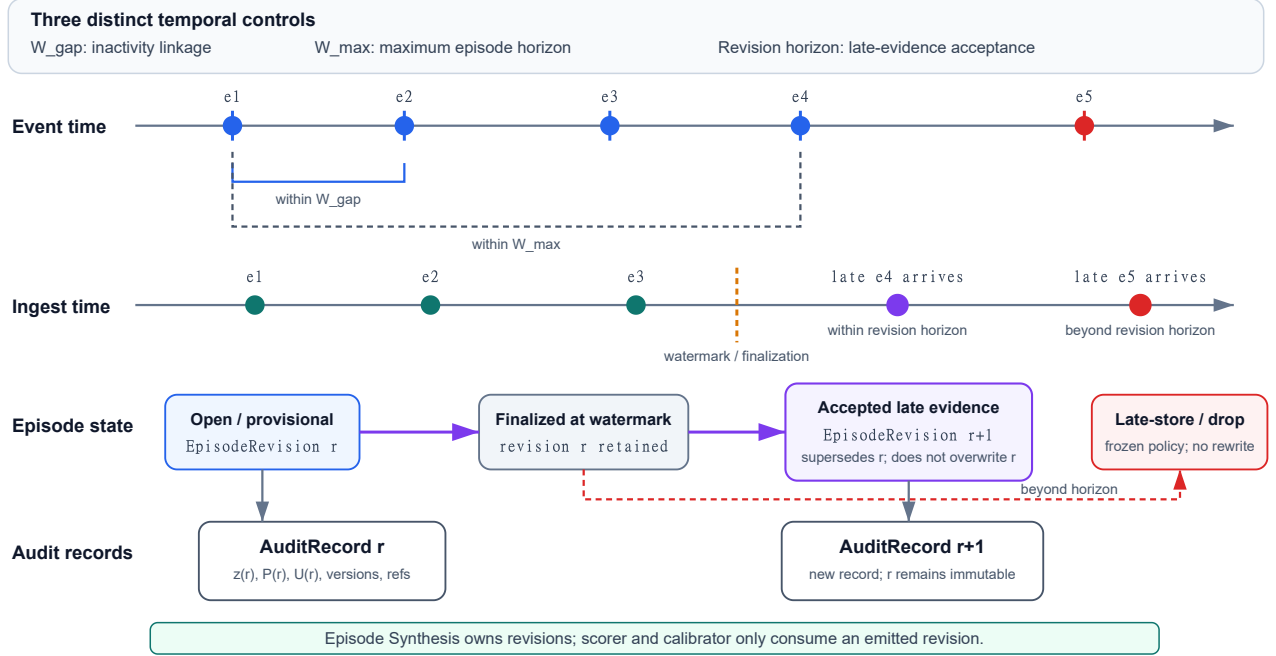


Figure 2: Deterministic episode and revision lifecycle. Event time governs linking under W_{gap} and W_{max} ; ingest time governs watermarks. Accepted late evidence creates a new immutable revision and AuditRecord, while evidence beyond the horizon cannot rewrite history.

Table 3: Core notation.

Symbol	Meaning
e_i	normalized event
$e^{(r)}$	immutable episode revision
$m_{\epsilon,s}$	observed source-family mask
h_{ϵ}	collector-health snapshot
$q_{\epsilon,s}$	independent detection support
D_{ϵ}	normalized detector-deviation feature
C_{ϵ}	EDR/NDR corroboration feature
z_{ϵ}	raw logit
P_{ϵ}	nullable calibrated maliciousness probability
κ_{ϵ}	calibration-support status
U_{ϵ}	structured evidence-sufficiency profile

and corroboration is

$$C_{\epsilon} = q_{\epsilon, \text{EDR}} q_{\epsilon, \text{NDR}}. \quad (7)$$

Heartbeat, inventory, and dependency-linked forwarded copies do not set $q = 1$. Identity, if available in a later pilot-gated study, remains an offline exploratory annotation: it does not enter NormalizedEvent, Episode Synthesis, candidate IDs or membership, D , C , any calibrator manifest, or a primary research question. Thus it cannot change the candidate universe, and S^* and $K = 2$ remain fixed.

The stateless scorer is

$$z_{\epsilon} = b + w_D D_{\epsilon} + w_C C_{\epsilon}, \quad w_D, w_C \geq 0. \quad (8)$$

Its only learned coefficients are (b, w_D, w_C) . Training minimizes unweighted candidate-level log loss; formation and feature settings are selected using training and development data, then frozen before the final train-only normalizer and scorer are fitted. Campaign/run is the split and uncertainty cluster. Health, m , κ , U , labels, and outage status never enter x_{ϵ} . The terms $w_D D_{\epsilon}$ and $w_C C_{\epsilon}$ are replayable logit decompositions, not causal explanations. Appendix A.3 records preprocessing artifacts, implementation settings, owners, and freeze points.

3.5 Manifest-Scoped Affine Calibration

Neither z_{ϵ} nor $\sigma(z_{\epsilon})$ is called a validated probability. The primary calibrator is a positive-slope global affine mapping fitted on an independent calibration split with natural candidate prevalence, following the score-to-probability principle of Platt scaling and evaluation with proper scoring rules [6, 13]:

$$P_{\epsilon} = \begin{cases} \sigma(az_{\epsilon} + b_{\text{cal}}), & \kappa_{\epsilon} = \kappa_G, \\ \sigma(agz_{\epsilon} + bg), & \kappa_{\epsilon} = \kappa_g, \\ \text{NA}, & \kappa_{\epsilon} = \kappa_{\emptyset}, \end{cases} \quad a, ag > 0. \quad (9)$$

$\kappa_{\emptyset}$ denotes out_of_support; κ_G and κ_g retain the status meanings defined after Equation 1. The global mapping preserves ranking over the same candidate set. A group mapping preserves ranking only within that group and makes no cross-group ranking claim. Group calibration is conditional: a pre-registered gate requires sufficient positive revisions, negative revisions, and independent runs plus evidence that the global mapping is inadequate. Selection and

fit use run-level cross-fitting or an internal calibration holdout, never the locked test.

Exact support requires the current episode, feature, detector, raw-model, label-policy, candidate-selection, and schema versions plus source mask to match the calibrator manifest. A supported group uses `supported_group`; a supported revision that fails only the group gate falls back to the primary global mapping as `supported_global`; a manifest or regime mismatch is `out_of_support`, stores canonical null for P , and sets `decision_eligible=false`. It retains z for diagnosis but no unvalidated number in $[0, 1]$ is named a probability. Appendix A.4 defines the resolver, manifest, gate, and invalidation matrix.

3.6 Independent Structured Sufficiency and Append-Only Audit

Evidence sufficiency is a structured state:

$$U_\epsilon = (u_{\text{coverage}}, u_{\text{provenance}}, u_{\text{lateness}}, u_{\text{contradiction}}, u_{\text{calibration}}). \quad (10)$$

U is not scalar confidence: its axes are never weighted, averaged, or one-hot ranked. It does not modify, gate, or relabel P . The contradiction axis reads only online evidence and cannot read scenario, ability, or label metadata. A downstream review or abstention policy may jointly consume P and U , but that policy is outside the method.

Each `EpisodeRevision` produces exactly one insert-only `AuditRecord` containing ordered membership and link reasons, D , C , z , nullable P , κ , U , source-health snapshot, evidence references, policy/model/calibrator versions, and a canonical digest. Accepted late evidence creates a complete new record in the revision chain. Canonical null, serialization, key, and hashing rules are specified in Appendix A.1.

3.7 Method Boundary and Reproducibility Contract

The method excludes CTI enrichment, RAG or agent components, impact or priority scoring, automated response, Identity as a primary source, OT/ICS generalization, ground-truth-assisted online inference, and downstream queue optimization. Its canonical replay payload excludes wall-clock execution timestamps and machine-specific runtime metadata. The contribution is limited to deterministic candidate-episode construction, compact version-scoped probability calibration, independent evidence-sufficiency reporting, and replayable append-only provenance under endpoint and network telemetry.

4 EVALUATION

The evaluation is a frozen, pre-registered contract rather than an open-ended list of experiments. Dataset roles, campaign-level partitions, artifacts, support gates, interventions, metrics, baselines, matching rules, and resampling units are fixed before the locked test is opened. Result cells remain pending until generated from measured runs; no synthetic performance value, curve, or confidence interval is used.

4.1 Research Questions and Claim Boundaries

RQ1 – episode formation fidelity. Does the frozen label-blind builder recover a larger fraction of malicious actions and paths than fixed-window and time-plus-entity comparators while reducing fragmentation, over-merge, and benign contamination?

RQ2 – ranking and probability calibration. Does the compact $D + C$ scorer improve AUPRC and fixed-budget recall over the registered severity comparator and D -only ablation? Does independent affine calibration improve Brier score, negative log-likelihood (NLL), and reliability? A positive-slope global mapping must leave AUPRC and AUROC unchanged on the same candidate set; a difference triggers an implementation audit. Conditional group mappings are checked only for within-group ranking and do not claim cross-group invariance.

RQ3 – partial telemetry and revision behavior. Under paired replay perturbations and a separate physical-collector outage procedure, how do formation, z , supported calibration, U , revisions, support status, and decision eligibility change?

RQ4 – reproducibility and cost. Do frozen inputs, ordering policy, and versions produce byte-identical canonical outputs? We measure throughput, p50/p95/p99 latency, peak memory, storage per event and revision, and replay time without defining an unmeasured *acceptable cost* threshold.

4.2 Dataset Roles and Controlled Laboratory

Tier 1 and Tier 2 are never pooled for scorer fitting or calibration. Tier 1 contains provenance-rich traces but not the primary EDR/NDR deployment contract. Tier 2 contains a Caldera control plane, isolated Windows and Linux targets, a benign service, EDR and NDR collectors, Health Monitor, production-like online pipeline, separate Ground Truth Store, and offline Evaluation Harness. Each run freezes clock-synchronization status, image hashes, collector configuration, random seed, and benign-workload manifest. Identity collection is only a pilot-gated offline extension: Identity observations are excluded from `NormalizedEvent`, `EpisodeSynthesis`, candidate IDs and membership, the primary features, and every calibrator manifest. Gate passage permits only a separately labeled post-inference exploratory analysis; $S^* = \{\text{EDR}, \text{NDR}\}$ and $K = 2$ never change. Field telemetry not yet collected is future external-validity work, not a current evaluation tier.

4.3 Ground Truth Firewall and Label Registry

Online schemas use explicit allowlists and deny evaluation-only fields. The firewall rejects:

- `operation_id`, `ability_id`, and `adversary_profile`;
- `technique_label`, attack marker, and attack window;
- `scenario_class` and `malicious_label`; and
- `split_assignment`.

These fields cannot enter `NormalizedEvent`, `SourceCoverage`, `EpisodeRevision`, `FeatureVector`, `AuditRecord`, or any online lookup. This boundary addresses target leakage at both schema and partition levels [7].

The versioned label registry freezes temporal tolerance, entity-overlap rule, minimum malicious overlap, benign-contamination

Table 4: Deterministic Evidence Sufficiency Profile.

Axis	Value set	Deterministic online inputs
coverage	complete; degraded; unavailable; unknown	deployment manifest and SourceCoverage
provenance	complete; partial; missing	raw pointers and entity/edge traces
lateness	stable; revisable; late-accepted; horizon-exceeded	watermark and revision state
contradiction	none; present; unevaluable	frozen online-only contradiction rules
calibration	supported-global; supported-group; out-of-support	Scope Resolver status κ

Table 5: Pre-registered dataset roles and claim boundaries.

Tier	Source	Permitted use	Forbidden claim
Tier 1	DARPA Transparent Computing E3 CADETS, THELA, and TRACE subsets with frozen schema and ground-truth mappings [4]	formation sanity checks and secondary path reconstruction	EDR/NDR calibration or deployment prevalence
Tier 2	Controlled Caldera v5.3.0 laboratory with EDR and NDR collection [2]	all primary formation, ranking, calibration, partial-telemetry, outage, and replay claims	generalization beyond the frozen manifest

threshold, adjudication procedure, exclusions, and sensitivity analyses. A *positive* revision passes the frozen malicious-overlap rule; a *negative* revision is attributable to benign/background activity and does not overlap an attack action within the frozen tolerances. A *mixed* revision exceeds both malicious and unrelated-benign overlap thresholds; an *ambiguous* revision cannot be uniquely adjudicated because of missing or conflicting time/entity evidence. Primary binary fitting and metrics use positive and negative revisions only; mixed and ambiguous counts are always reported and enter the pre-registered sensitivity view. Test labels cannot select formation, features, groups, calibration mappings, thresholds, or bins.

4.4 Scenario and Benign Workload Catalogue

M5’s EDR/NDR endpoint actions may enter the primary analysis independently of the Identity gate; Identity observations never do. A passed gate permits only a separately labeled offline exploratory annotation. Replay variants formerly called M8 are interventions in Section 4.8, not independent malicious scenarios. The benign catalogue contains B1 inventory scripting, B2 patch deployment, B3 file-share synchronization, B4 vulnerability scanning, B5 helpdesk remote administration, B6 log collection, B7 configuration management, and B8 unscheduled maintenance. The same tools appear in benign and malicious contexts. Pure benign, attack-only, and concurrent attack-plus-benign runs are all collected. Appendix A.5 freezes family-level admission, repetition, cleanup, and failed-run handling; the companion reproducibility appendix retains each card’s ordered preconditions, harmless markers, expected observations, and cleanup procedure.

4.5 Campaign-Level Splits and Artifact Freeze

The independent partition unit is a complete campaign/run. All events, episodes, revisions, paired replays, and paired outage records from a base run remain in one mutually exclusive partition and one bootstrap cluster.

- (1) Engineering smoke runs verify schemas, clocks, collection, and raw pointers; they never enter formal results.
- (2) Pilot runs estimate candidate prevalence, episode size, source-mask support, and perturbation feasibility.

- (3) Training fits each candidate normalizer and scorer; development selects formation, feature, and implementation settings.
- (4) After those choices freeze, final train-only normalization and scorer artifacts are produced.
- (5) The natural-prevalence calibration split fits the affine mapping and executes the pre-registered group gate.
- (6) The locked test is evaluated once with all artifacts, bins, metrics, and analysis scripts frozen.
- (7) A method change invalidates affected calibrators and requires a separately identified confirmatory test.

No event- or episode-level random split is permitted. Calibration selects no feature, and the locked test selects no threshold, group, fallback, bin, baseline, or metric.

4.6 Calibration Protocol and Support Gate

Calibration has three separate procedures. First, training fits the constrained raw scorer, and development freezes its contract. Second, the natural-prevalence calibration split fits the primary global affine mapping. Third, the manifest resolver assigns supported_global, supported_group, or out_of_support. Conditional group selection and fitting use the internal run-level procedure in Appendix A.4; the locked test never chooses a group.

Every supported calibration result reports candidates, positives, negatives, independent runs, prevalence, uncalibrated-sigmoid and calibrated Brier/NLL, a reliability diagram with bin counts, and campaign-level 95% intervals. AUPRC and AUROC measure ranking, not calibration. Unsupported records report out-of-support rate, supported decision coverage, raw-logit distribution, U state, and error categories; they are excluded from calibrated Brier, NLL, and reliability calculations. CORP-style decomposition is exploratory and reported only in the companion reproducibility appendix.

4.7 Baselines and Component Ablations

All comparisons use the same run partitions, ground-truth policy, and eligible candidate population for the question they answer.

The fixed-weight $D + C$ heuristic, nonlinear capacity check, optional benign-context feature, and any ablation in which removing

The diagram illustrates the Evidence Fabric architecture, divided into two main roles by a Firewall:

- ONLINE INFERENCE ROLE - LABEL BLIND** (Left side, blue background):
 - Telemetry**: events + health
 - TrustEpisode**: fabric → episode → score calibration + U
 - Emitted outputs**: EpisodeRevision, one immutable AuditRecord per revision
 - Automated online-schema checks**:
 - Allowed: event IDs · timestamps · source IDs · entities · actions · raw refs
 - Forbidden: operation_id · ability_id · adversary_profile · technique_label · attack marker / window · scenario_class · malicious_label · split_assignment
 - Reject record or fail the test when any forbidden field is present
- OFFLINE EVALUATION ROLE** (Right side, orange background):
 - Ground Truth Store**: Caldera + benign workload manifests, versioned GT fields and run metadata, offline database role only
 - Evaluation Harness**: join after online inference, frozen label_policy_version, positive · negative · mixed · ambiguous
 - Metrics and labels never feed back** to Evidence Fabric, episode formation, features, or scores

A **FIREWALL** separates the two roles. Data flow includes:

- Telemetry → TrustEpisode → Emitted outputs
- Emitted outputs → Automated online-schema checks
- Automated online-schema checks → Evaluation Harness (via Firewall)
- Evaluation Harness → Ground Truth Store (via Firewall)
- Ground Truth Store → Evaluation Harness (via Firewall)
- Metrics and labels never feed back to Evidence Fabric, episode formation, features, or scores

 A red 'X' marks the Firewall. A note at the bottom right states: "immutable online outputs only".

Table 6: Controlled malicious scenario families.

ID	Single implementation	Purpose
EB1	non-overlapping fixed event-time windows	external time-only comparator
EB2	EB1 plus at least one specific shared entity	external time-plus-entity comparator
EB3	proposed deterministic temporal-causal builder	proposed reference
EB3-H	EB3 with hub suppression disabled	one component ablation for giant-component risk

4.8 Paired Replay Perturbations and Physical Outage

8

Table 8: Registered scoring and calibration comparisons.

ID	Single implementation	Purpose
SB1	maximum normalized source-native severity in the episode	external ranking comparator; no probability metrics
SB2	constrained D -only logit	ablate independent corroboration
SB3	proposed $D + C$ raw logit z	proposed raw ranking
SB4	$\sigma(z)$ without calibration	uncalibrated probability comparator
SB5	SB3 plus primary global affine calibration	proposed calibrated method
SB6	pre-registered supported group calibration	conditional exploratory analysis
SB7	unavailable-source detector values forced to zero while support is ignored	robustness anti-pattern comparator

Physical outage is a separate procedure. A collector is actually stopped or isolated; authenticated heartbeat transitions to degraded/down; SourceCoverage changes; and the pipeline is observed through watermark, revision, scope-status, eligibility, recovery, and stabilization behavior. Every outage run has a `pair_id` linking it to a normal run with the same scenario and seed. Paired records remain in one split and bootstrap cluster. Replay and outage outcomes are never pooled. All perturbation levels and outage durations are frozen before locked test access.

4.9 Metrics and Statistical Analysis

RQ1 primary outcomes are malicious-action coverage, fragmentation rate, and over-merge rate. Benign contamination and episode precision/recall/F1 under the frozen matching rule are secondary. RQ2 ranking outcomes are AUPRC and recall at the fixed analyst-review budget; Brier, NLL, and reliability are the calibration outcomes. AUPRC is emphasized for the imbalanced candidate population [14]. AUROC and precision at k are secondary.

RQ3 has two non-pooled views. The replay table reports paired formation changes, z shift, supported-regime Brier/NLL degradation, supported decision coverage, every U axis, revision count, and stabilization. The physical-outage table reports health-detection latency, SourceCoverage transitions, decision eligibility, recovery, and stabilization; out-of-support records receive no calibrated proper score. RQ4 checks equality of the canonical replay hash and reports throughput, run-level p50/p95/p99 latency, peak memory, storage per event/revision, and replay time. Hardware, concurrency, warm-up, and measurement interval are frozen.

Campaign/run is the only resampling unit. Confidence intervals use a cluster bootstrap by run [5]; replay and outage contrasts are paired by base run. We report absolute differences with 95% intervals and treat relative differences as supplemental. Every subgroup reports runs, candidates, positives, negatives, and prevalence. Event latency is summarized inside each run before run-level aggregation. U is never scalarized and no single U -AUC is computed. Appendix A.6 gives formulas, matching, bootstrap seed, and the full RQ matrix.

4.10 Reporting Plan

Results are populated only by the locked analysis pipeline. R1 reports split/run/candidate and label counts. The primary method tables deliberately separate formation from ranking and calibration:

The separately structured R3a ranking and R3b supported-calibration shells appear in Appendix A.6; moving the empty

registries does not change their frozen columns or the main-text reporting contract.

R4 reports paired replay perturbations; R5 reports physical outage and recovery; R6 reports determinism and resource cost; and R7 reports error categories. Planned result figures are raw versus calibrated reliability, reliability by supported mask, decision coverage, builder fragmentation/contamination, and measured revision behavior. They are intentionally absent until real locked-test outputs exist.

4.11 Limitations and Safety

The controlled laboratory does not represent every deployment, evasion strategy, or base rate. DARPA TC supports only the formation claim. Calibration applies only to the frozen manifest and explicitly supported regimes. Identity remains offline and exploratory even if its pilot gate passes; it cannot alter primary candidates or outputs. Uncollected field data are not part of the present evaluation. Emulation uses isolated hosts, test accounts, harmless markers, cleanup manifests, and recorded failed or aborted runs. The evaluation does not study CTI, agent components, impact, priority, or autonomous response.

5 CONCLUSION

We presented TRUSTEPISODE, a multi-layer method for calibrated episode risk scoring over heterogeneous security telemetry. The system combines an Evidence Fabric Layer, Episode Synthesis Layer, Calibrated Trust Scoring Layer, and Agentic Evidence Assurance Layer. Its central contribution is a constrained, learnable, and auditable method that separates maliciousness likelihood from operational impact, exposes evidence sufficiency as an explicit state, bounds CTI contribution, and preserves trace-transparent factor evidence.

Unlike static correlation, TRUSTEPISODE adapts score contributions to observed behavior. Unlike unconstrained LLM triage, its numerical outputs remain calibrated, reproducible, and traceable to evidence. The proposed three-tier evaluation unifies public provenance traces, controlled BAS validation, and enterprise external validation to assess reconstruction, ranking, calibration, robustness, and operational utility.

Paired partial-telemetry perturbations and separate physical-outage validation

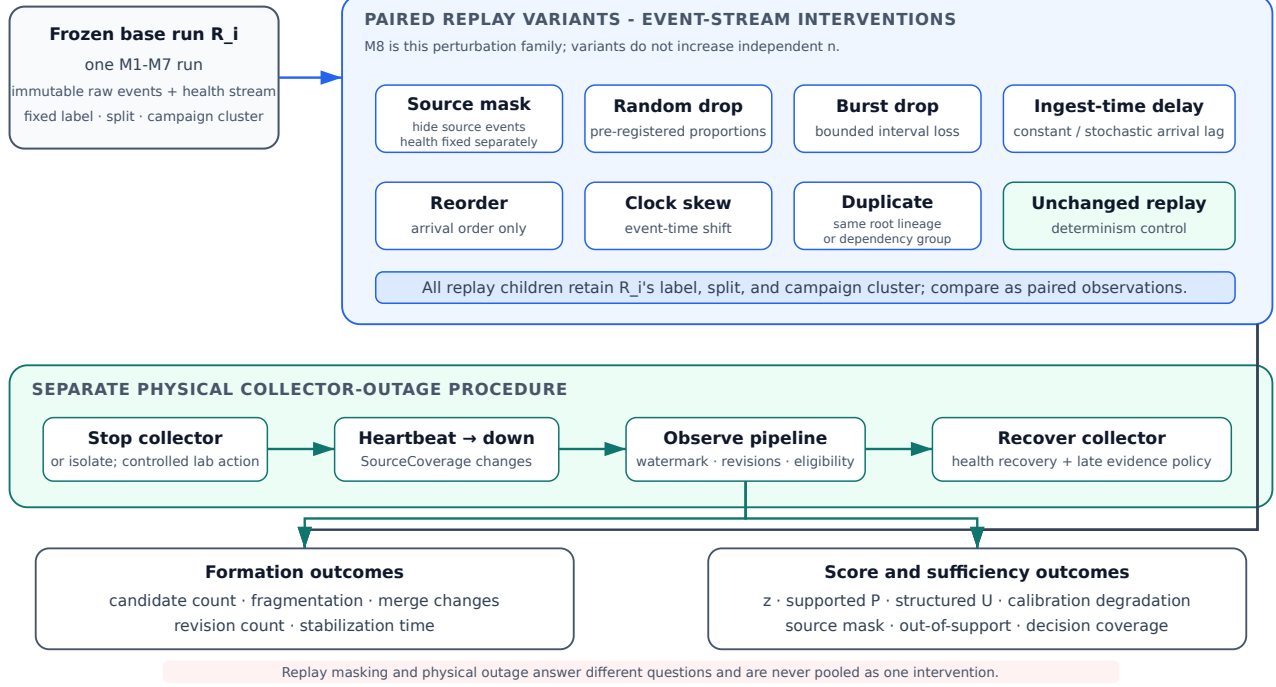


Figure 4: Paired replay perturbations and separate physical-outage validation. Replay masking changes observed events without claiming collector failure; physical outage changes authenticated health and is analyzed independently.

Table 9: R2 formation-result shell. All cells remain pending until locked evaluation.

Builder	Action coverage ↑	Fragmentation ↓	Over-merge ↓	Contamination ↓	Episode F1 ↑
EB1	—	—	—	—	—
EB2	—	—	—	—	—
EB3	—	—	—	—	—
EB3-H	—	—	—	—	—

A FROZEN SUBMISSION CONTRACTS

A.1 Online Data and Audit Contract

All online objects are versioned, immutable after emission, and validated against an allowlist. Table 10 is the contract-complete registry; optional fields may be absent but cannot change a required field’s meaning.

Identifiers are non-empty UTF-8 strings. Times are UTC RFC 3339 at microsecond precision. Health is {healthy, degraded, down, unknown, not_applicable}. Raw pointers contain an immutable object ID, SHA-256 digest, record locator, and storage-schema version. Canonical JSON uses lexical keys, domain-ordered arrays, shortest round-trip decimals, and no NaN/infinity; unsupported P is literal null. The SHA-256 payload excludes host/time/process runtime metadata. Online allowlists reject labels, scenario/operation/ability IDs, attack windows/markers, and split assignments. Storage denies UPDATE/DELETE; a correction emits a successor revision and record.

A.2 Episode Synthesis and Replay

Eligibility uses inclusive W_{gap} and W_{max} bounds and requires at least one process-causal, authenticated-session, endpoint-mapped connection, or specific-entity relation; hub-only support is forbidden. Candidates use the sole total order

$$(-\rho, -n_R, \Delta_t, t_{\text{start}}, \text{episode_id}), \quad (11)$$

with relation precedence process-causal, session, endpoint-mapped, then entity equality. Zero, one, and multiple candidates respectively start, attach, or merge only when component and cross-episode guards pass; otherwise the first ordered candidate receives the event. Start IDs hash policy version, first event ID, and namespace; merge IDs hash merge, sorted parent IDs, and policy version. Membership order is $(t_{\text{event}}, t_{\text{ingest}}, \text{source_instance}, \text{event_id})$. Event time controls relations; ingest time controls the watermark. Accepted late evidence emits $r+1$ and one new AuditRecord. Replay equality covers IDs, membership, links, lineage, D, C, z, P, κ, U , versions, evidence references, and canonical digests.

Table 10: Canonical online schema registry.

Object	Key	Required content	Permitted optional content
NormalizedEvent	event_id	UTC event/ingest times; source family/instance; canonical subject, object, action; immutable raw pointer; dependency group; schema/parser versions	allowlisted source-native attributes
SourceCoverage	source instance plus interval start	interval end; expected flag; health enum; lag; reason; monitor/policy versions	authenticated diagnostic reference
EpisodeRevision	episode ID plus revision	ordered event IDs/link reasons; parent/merge lineage; event-time bounds; watermark; formation-policy version; membership digest	late-evidence reason; predecessor ID
FeatureVector	episode ID plus revision	D, C ; feature version; normalizer hashes; feature-input references	missing-value reason
AuditRecord	episode ID plus revision	revision digest; D, C, z, P, κ, U ; model/calibrator/manifest versions; health snapshot; evidence references; canonical digest	non-canonical runtime envelope

A.3 Feature and Parameter Registry

The single threshold registry assigns $W_{\text{gap}}, W_{\text{max}}, f_{\text{hub}}, n_{\text{component}}$ to formation policy; $W_{\text{rev}}, L_{\text{wm}}$ to revision policy; $\theta_{\text{mal}}, \theta_{\text{contam}}$ to label policy; $n_{\text{pos}}^{\min}, n_{\text{neg}}^{\min}, n_{\text{run}}^{\min}, \Delta_{\text{miscal}}^{\min}$ to the calibration gate; and θ_{match} to evaluation policy. Formation values freeze before final training, revision and calibration gates before calibration, and label/matching rules before locked-test access. The unconditional method has five fitted scalars; empirical CDFs are fitted artifacts, not constants.

A.4 Calibration Manifest and Eligibility

The manifest binds formation/candidate/label policy; feature and detector contracts; CDF, raw-model, coefficient, train-split, calibration-split, and calibrator digests; exact source masks and health regimes; schema/parser/pipeline versions; support counts; gate evidence; and reliability bins. No nearest-mask or nearest-version match is allowed. A group is enabled only after pre-registered positive, negative, and independent-run minima and held-out run-fold improvement in both Brier and NLL without direction reversal. Gate failure falls back to supported_global; any required contract mismatch yields out_of_support, canonical-null P , and decision_eligible=false.

A.5 Laboratory and Offline Labels

Every run manifest freezes run/pair IDs; scenario/workload versions; Caldera commit; target, collector, and container hashes; topology; EDR/NDR/Health Monitor configuration; parser/schema versions; clock source/skew; seed; harmless marker; cleanup; and incidents. M1–M7 run alone and with B1–B8; each card fixes repetition before locked collection. Collection failure remains in R1/failure logs but leaves primary metrics; action failure with healthy collectors enters only the sensitivity cohort; cleanup failure blocks reuse of that image. Ground truth is stored under a separate role and joins only after AuditRecord insertion by run ID, harmless marker, entity namespace, time interval, and label-policy digest. The companion reproducibility appendix retains each card’s ordered actions, expected observations, and cleanup procedure.

Identity is excluded from NormalizedEvent, Episode Synthesis, candidate IDs/membership, D, C, z , every calibrator manifest, and all primary RQs. A timestamp/provenance/health/support pilot gate may permit only an offline, separately labeled exploratory annotation after primary inference; it cannot alter the EDR/NDR candidate universe or $K = 2$ contract.

A.6 Experimental and Result Contract

A predicted stabilized revision is match-eligible only inside the registered time/entity scope and above θ_{match} . Maximum-weight bipartite assignment maximizes covered malicious actions; ties use entity overlap, absolute time difference, then lexical IDs. For malicious-action set A and assigned covered actions $\hat{A}$,

$$\text{ActionCoverage} = |A \cap \hat{A}|/|A|, \quad (12)$$

$$\text{Fragmentation} = |G|^{-1} \sum_{g \in G} \max(0, n_g - 1). \quad (13)$$

Over-merge is the fraction of revisions eligible for multiple runs; contamination is the unrelated-benign event fraction in revisions assigned to malicious runs. For supported records,

$$\text{Brier} = n_{\text{sup}}^{-1} \sum_i (P_i - Y_i)^2, \quad (14)$$

$$\text{NLL} = -n_{\text{sup}}^{-1} \sum_i [Y_i \log P_i + (1 - Y_i) \log(1 - P_i)]. \quad (15)$$

Unsupported records are excluded from both. Reliability uses ten fixed equal-width bins with counts; supported coverage is $|C_{\text{sup}}|/|C|$; fixed-budget recall uses the top $\max(1, \lceil 0.05|C_{\text{run}}| \rceil)$ revisions per run. Primary intervals use 2,000 complete-run cluster-bootstrap resamples with seed 20260710; replay/outage contrasts resample base-run pairs.

REFERENCES

- [1] Tyler Akidau, Robert Bradshaw, Craig Chambers, Slava Chernyak, Rafael J. Fernández-Moctezuma, Reuven Lax, Sam McVeety, Daniel Mills, Frances Perry, Eric Schmidt, and Sam Whittle. 2015. The Dataflow Model: A Practical Approach to Balancing Correctness, Latency, and Cost in Massive-Scale, Unbounded, Out-of-Order Data Processing. *Proceedings of the VLDB Endowment* 8, 12 (2015), 1792–1803. <https://doi.org/10.14778/2824032.2824076>
- [2] Apache Software Foundation. 2026. CALDERA: Automated Adversary Emulation Platform. GitHub repository. <https://github.com/apache/caldera> Version 5.3.0, commit dd22d543a519afe63ca35c454bf1add5d75c45dc; accessed 2026-07-10.
- [3] Zijun Cheng, Qiujian Lv, Jinyuan Liang, Yan Wang, Degang Sun, Thomas Pasquier, and Xueyuan Han. 2024. KAIROS: Practical Intrusion Detection and Investigation using Whole-system Provenance. In *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 3533–3551. <https://doi.org/10.1109/SP54263.2024.00005>
- [4] DARPA Information Innovation Office. 2026. Transparent Computing Program Materials: E3 CADETS, THEIA, and TRACE Releases. GitHub repository. <https://github.com/darpa-i2o/Transparent-Computing> Repository commit 244ae2401032ce92ac3b72f49b8039cae67d60d6; accessed 2026-07-10.
- [5] C. A. Field and A. H. Welsh. 2007. Bootstrapping Clustered Data. *Journal of the Royal Statistical Society: Series B (Statistical Methodology)* 69, 3 (2007), 369–390. <https://doi.org/10.1111/j.1467-9868.2007.00593.x>
- [6] Tilmann Gneiting and Adrian E. Raftery. 2007. Strictly Proper Scoring Rules, Prediction, and Estimation. *J. Amer. Statist. Assoc.* 102, 477 (2007), 359–378. <https://doi.org/10.1198/016214506000001437>
- [7] Shachar Kaufman, Saharon Rosset, Claudia Perlich, and Ori Stitelman. 2012. Leakage in Data Mining: Formulation, Detection, and Avoidance. *ACM Transactions on Knowledge Discovery from Data* 6, 4, Article 15 (2012), 21 pages. <https://doi.org/10.1145/2382577.2382579>

Table 11: Parameter, owner, fit data, and freeze registry.

Category	Content	Fit?	Owner	Fit/selection data	Freeze
Raw scorer	(b, w_D, w_C)	yes	Stateless Scorer	training; development selects con- tract	before calibration
Global mapping	(a, b_{cal})	yes	Calibrator	natural-prevalence calibration split	before locked test
Group mapping	(a_g, b_g)	conditional	Calibrator	calibration run folds after gate	before locked test
Formation/revision	time, watermark, hub, component, merge settings	no	Episode Synthesis	training/development or pilot	before final fit
Feature policy	empirical CDF hashes; top three; $K = 2$	CDF only	Feature Extractor	training-benign; P0 fixed constants	before scorer fit
Runtime state	m, h, q, κ, U	no	declared Table 2 producers	online observations/rules	per revision
Evaluation	split seed; matching; perturbations; bootstrap	no	Evaluation Harness	pilot/development preregistration	before locked test

Table 12: Calibrator invalidation matrix.

Change	Immediate status	Required action
Episode/candidate policy	invalid	rebuild candidates; refit scorer and calibrator
Feature, normalizer, or missing rule	invalid	refit scorer and calibrator
Detector contract or parser semantics	out of support	revalidate features; refit if meaning/distribution changes
Raw model or training population	invalid	refit calibrator
Label policy	invalid supervised claim	regenerate labels; repeat fit/evaluation
Source mask or health regime	out of support	collect support; register new manifest
Additive schema field excluded from features	compatibility pending	prove canonical equivalence before amendment
Candidate-prevalence drift	revalidation signal	audit reliability; do not alter per-revision output automatically

Table 13: Frozen RQ matrix and R3 result shells. Every unexecuted cell is pending, never zero.

RQ	Comparison/intervention	Primary outcomes	Unit
RQ1	EB1, EB2, EB3, EB3-H	action coverage; fragmentation; over-merge	campaign/run
RQ2	SB1-SB5; SB6 conditional	AUPRC; fixed-budget recall; Brier; NLL; reliability	campaign/run
RQ3	paired replay grid; separate outage pairs	formation/z/support/U/revision changes; outage detection/recovery	base-run pair
RQ4	unchanged replay; frozen hardware	canonical digest equality; throughput; latency; memory; storage; replay time	campaign/run

R3a: ranking over common candidates				
Scorer	AUPRC	R@budget	AUROC	P@k
SB1 severity	—	—	—	—
SB2 <i>D</i> only	—	—	—	—
SB3 <i>D</i> + <i>C</i>	—	—	—	—

R3b: supported calibration only					
Map	Brier	NLL	Rel.	Cov.	OOS
SB4 $\sigma(z)$	—	—	pending	—	—
SB5 global	—	—	pending	—	—
SB6 group	—	—	pending	—	—

- [8] Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen tau Yih, Tim Rocktäschel, Sebastian Riedel, and Douwe Kiela. 2020. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks. In *Advances in Neural Information Processing Systems*, Vol. 33. Curran Associates, Inc., Red Hook, NY, USA, 9459–9474.
- [9] Shaofei Li, Feng Dong, Xusheng Xiao, Haoyu Wang, Fei Shao, Jiedong Chen, Yao Guo, Xiangqun Chen, and Ding Li. 2024. NODLINK: An Online System for Fine-Grained APT Attack Detection and Investigation. In *Proceedings of the Network and Distributed System Security Symposium (NDSS)*. Internet Society, Reston, VA, USA, 18 pages. <https://doi.org/10.14722/ndss.2024.23204>
- [10] Sadegh M. Milajerdi, Rigel Gjomemo, Birhanu Eshete, R. Sekar, and V. N. Venkatakrishnan. 2019. HOLMES: Real-time APT Detection through Correlation of Suspicious Information Flows. In *2019 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 1137–1152. <https://doi.org/10.1109/SP.2019.00026>
- [11] Peng Ning, Yun Cui, and Douglas S. Reeves. 2002. Constructing Attack Scenarios through Correlation of Intrusion Alerts. In *Proceedings of the 9th ACM Conference on Computer and Communications Security*. Association for Computing Machinery, New York, NY, USA, 245–254. <https://doi.org/10.1145/586110.586144>
- [12] Open Cybersecurity Schema Framework. 2026. OCSF Schema. Schema specification and GitHub repository. <https://github.com/ocsf/ocsf-schema> Version 1.8.0, commit 6fa6499a0f8c9f449d342816e90e5f687c224b0a; accessed 2026-07-10.
- [13] John C. Platt. 1999. Probabilistic Outputs for Support Vector Machines and Comparisons to Regularized Likelihood Methods. In *Advances in Large Margin Classifiers*, Alexander J. Smola, Peter L. Bartlett, Bernhard Schölkopf, and Dale Schuurmans (Eds.). MIT Press, Cambridge, MA, 61–74. <https://doi.org/10.7551/mitpress/1113.003.0008>
- [14] Takaya Saito and Marc Rehmsmeier. 2015. The Precision-Recall Plot Is More Informative than the ROC Plot When Evaluating Binary Classifiers on Imbalanced Datasets. *PLOS ONE* 10, 3 (2015), e0118432. <https://doi.org/10.1371/journal.pone.0118432>
- [15] Lingzhi Wang, Xiangmin Shen, Weijian Li, Zhenyuan Li, R. Sekar, Han Liu, and Yan Chen. 2025. Incorporating Gradients to Rules: Towards Lightweight, Adaptive Provenance-based Intrusion Detection. In *Proceedings of the Network and Distributed System Security Symposium (NDSS)*. Internet Society, Reston, VA, USA, 18 pages. <https://doi.org/10.14722/ndss.2025.230822>

Use of Generative AI. Generative AI tools were used as writing and editing assistants for language revision, consistency checking, figure drafting, and $\LaTeX$ formatting. The authors reviewed and remain responsible for all research claims, methods, sources, analyses, and final text. No AI-generated empirical data or results are reported.